

DEVOPS E ARQUITETURA CLOUD

FASE 3 | AULA 01 -

PRINCIPAIS AMEAÇAS EM AMBIENTES CLOUD

SUMÁRIO

O QUE VEM POR AÍ?	3
HANDS ON	4
SAIBA MAIS.....	5
MERCADO, CASES E TENDÊNCIAS	18
O QUE VOCÊ VIU NESTA AULA?	19
REFERÊNCIAS.....	20

EMANIP

O QUE VEM POR AÍ?

Bem-vindos e bem-vindas! Nesta aula, vamos mergulhar fundo no universo da segurança em cloud, com foco nas principais ameaças que afetam esses ambientes — um tema de crescente relevância em um mundo cada vez mais digital e conectado.

A computação em cloud, que já foi uma tendência, hoje é a espinha dorsal da transformação digital para empresas de todos os portes. Com um mercado que ultrapassou \$900 bilhões em 2025, a cloud se consolidou como o principal motor de inovação, agilidade e escalabilidade.

Nesta aula, vamos explorar o cenário de ameaças em constante evolução, entender como os atacantes pensam e, o mais importante, aprender as melhores práticas para proteger nossos ambientes, garantindo que a cloud seja uma aliada segura e confiável em nossa jornada tecnológica.

HANDS ON

Nestas videoaulas, veremos com mais detalhes como se prevenir utilizando o guia do OWASP TOP 10, onde vamos explorar cada categoria e como identificar e mitigar algumas das ameaças.

O vídeo irá te guiar através de cenários reais, mostrando as ferramentas e técnicas que os profissionais de segurança utilizam no dia a dia para proteger os ativos na nuvem.

EMANSP

SAIBA MAIS

A computação em nuvem deixou de ser apenas uma tendência ou um “Hype” de tecnologia e se tornou um pilar na transformação digital nas empresas. Voltando uns 20 anos atrás, ampliar um datacenter para escalar os sistemas era um processo caro e complicado. Era preciso contratar espaço físico, adquirir equipamentos e ainda contar com mão de obra especializada. Muitas vezes, tudo isso era feito apenas para atender uma demanda pontual, como por exemplo, uma campanha de Black Friday. Porém, no resto do ano, esses recursos acabavam ficando ociosos.

As empresas investiam pesadamente em datacenters próprios, com servidores físicos, armazenamento local e equipes internas dedicadas à manutenção da infraestrutura. Esse modelo exigia altos custos com energia, espaço físico, refrigeração e pessoal especializado. Hoje, esse cenário mudou radicalmente.

Porém, além da grande mudança na facilidade de obter recursos ou serviços com serviços em cloud, surgiu também um novo desafio: a segurança. Antes, nos datacenters tradicionais, a principal preocupação era com o espaço físico. Já na era da computação em cloud, estamos expostos à internet e, conseqüentemente, mais vulneráveis. Essa evolução trouxe uma verdadeira mudança de paradigma em segurança da informação.

No modelo tradicional, a proteção estava concentrada no físico: os servidores ficavam dentro da empresa, protegidos por firewalls e sistemas de rede. O controle de acesso físico e a confiança em uma rede interna “fechada” eram suficientes para reduzir grande parte das ameaças. Já no modelo em cloud, esse “requisito” praticamente desaparece.

Em outras palavras, a segurança em cloud não se limita a impedir invasões externas, envolve também garantir que configurações, identidades, permissões e dados sejam gerenciados corretamente. A superfície de ataque aumenta consideravelmente, e os riscos se tornam mais complexos.

Os dados e as aplicações estão distribuídos globalmente, acessíveis pela internet em diferentes contextos de uso, e conectadas por APIs, dispositivos móveis e integrações com parceiros.

Para entender sobre o que estamos falando, relatórios de mercado, como os do Gartner, mostram que os investimentos em cloud pública têm crescido, em média, 20% ao ano, alcançando cifras que já ultrapassam trilhões de dólares globalmente. Isso reflete a preferência das organizações por consumir infraestrutura como serviço (IaaS), plataformas como serviço (PaaS) e software como serviço (SaaS), em vez de manter toda a infraestrutura internamente. A cloud oferece escalabilidade, flexibilidade e velocidade de inovação, fatores essenciais em um mundo cada vez mais digital e competitivo. Veja o gráfico a seguir para entender a evolução nos últimos anos.

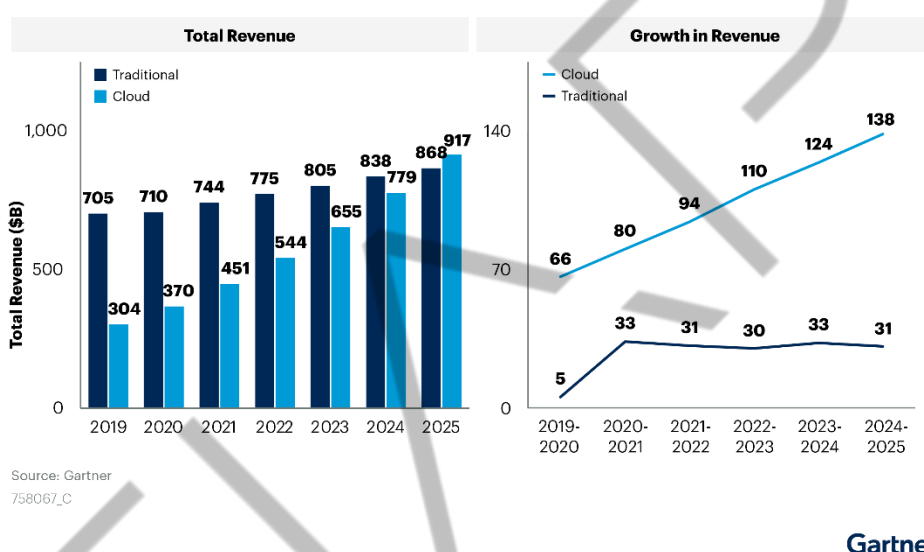


Figura 1 – Growth in Revenue 2024
Fonte: Gartner (2025)

A adoção da computação em cloud teve um aumento exponencial nos últimos anos. A flexibilidade, a escalabilidade e a eficiência de custos oferecidas pelos provedores de cloud como AWS, Microsoft Azure e Google Cloud transformaram a maneira como as empresas operam e inovam. De acordo com Gartner, os gastos mundiais dos usuários finais com serviços de cloud pública devem atingir \$723,4 bilhões em 2025, um aumento significativo em relação aos \$595,7 bilhões em 2024.

Este crescimento é impulsionado pela necessidade de modernização das aplicações, pela análise de grandes volumes de dados (Big Data), pela Inteligência Artificial (IA) e pela Internet das Coisas (IoT). Como podemos observar no próximo gráfico, a tendência de crescimento é clara e robusta em todos os segmentos de serviços em cloud (IaaS, PaaS e SaaS).

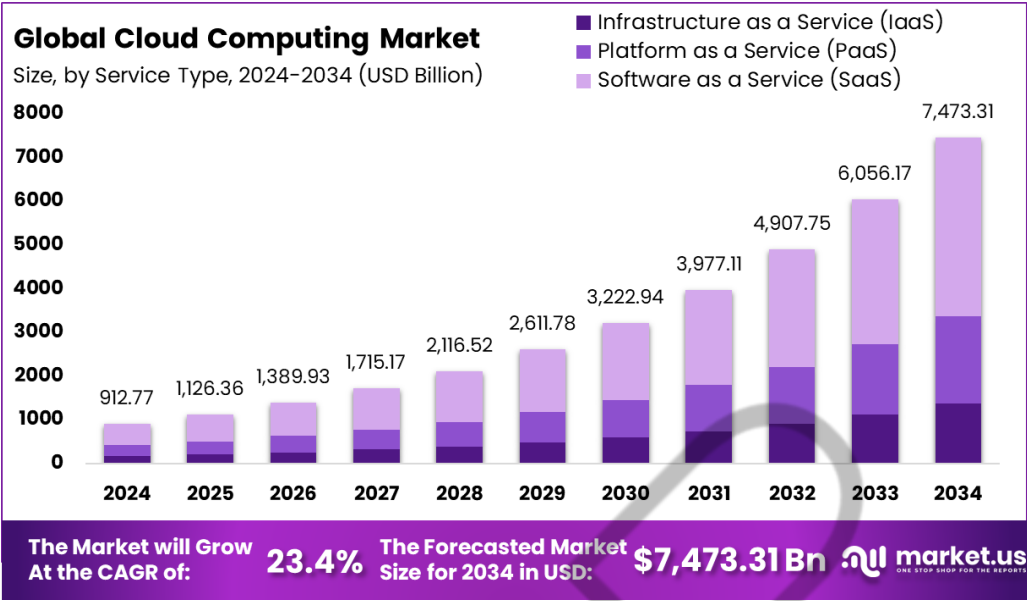


Figura 2 – Gráfico de crescimento do mercado de cloud.
Fonte: Market.us (2024)

Para entender a mudança que uma arquitetura cloud representa, é importante comparar o modelo de datacenter tradicional com o modelo de computação em nuvem. Enquanto o datacenter tradicional exige um alto investimento inicial em hardware, espaço físico e manutenção, a cloud oferece um modelo de pagamento conforme o uso (pay-as-you-go), eliminando a necessidade de grandes despesas de capital (CAPEX), transformando-as em despesas operacionais (OPEX).

A grande maioria das empresas já utiliza parte de sua infraestrutura hospedada em ambientes de cloud. A razão para isso é que o centro de dados utilizando uma arquitetura em cloud oferece uma série de vantagens em relação à manutenção de um centro de dados local. Alguns dos prós e contras do centro de dados baseado em cloud versus local incluem:

Característica	Datacenter Tradicional	Cloud Computing
Custo	Alto custo inicial (CAPEX).	Pagamento conforme o uso (OPEX).
Escalabilidade	Limitada e demorada.	Elástica e sob demanda.
Manutenção	Gerenciada pela própria empresa.	Gerenciada pelo provedor de cloud.
Agilidade	Baixa.	Alta.

Segurança Física	Responsabilidade da empresa.	Responsabilidade do provedor.
Acessibilidade	Acesso local ou via VPN.	Acesso global via internet.

Tabela 1 – Comparativo DataCenter
Fonte: Elaborado pelo autor (2025)

Compreender a diferença entre ameaças tradicionais e ameaças em ambientes em cloud é essencial para adotar práticas de segurança eficazes. Enquanto no passado os principais riscos estavam relacionados a ataques físicos ou a exploração de falhas em redes locais, na cloud o foco se desloca para erros de configuração, acessos indevidos e má gestão de identidades e dados.

No modelo tradicional com datacenter, as maiores preocupações de segurança estavam ligadas a problemas físicos e locais, como o risco de roubo ou dano dos servidores, infecção de computadores por vírus e ataques que exploravam falhas dentro da própria rede da empresa.

Porém, quando falamos em cloud, os riscos mudaram bastante. Hoje, o maior perigo está na exposição indevida de dados — muitas vezes causadas por falhas de configuração nos sistemas, especialmente nos de armazenamento. Exemplos comuns incluem o uso de APIs inseguras, que podem ser exploradas por hackers, má gestão de acessos, quando usuários recebem permissões além do necessário ou têm suas credenciais comprometidas.

Quando estamos falando em computação em nuvem, muitas pessoas ainda se confundem achando que não é preciso se preocupar com segurança, já que “tudo é gerenciado pelo provedor”. E é justamente aí que começa o erro. Trabalhar em uma arquitetura em Cloud exige ainda mais atenção à segurança, e a diferença fica evidente quando entendemos o modelo de responsabilidade compartilhada.

No **Shared Responsibility Model**, o provedor de cloud (AWS, Azure, Google Cloud, entre outros) assume a responsabilidade pela segurança da infraestrutura: datacenters, servidores físicos, rede e hardware. Já o cliente é responsável pela segurança dentro da cloud: configuração correta dos serviços, gestão de usuários e credenciais, proteção dos dados armazenados e implementação de políticas adequadas de acesso e monitoramento.

Esse conceito é essencial porque desmonta um mito comum: a ideia de que “a cloud não é segura”. Na prática, os grandes provedores investem bilhões em segurança física e lógica da infraestrutura. O que realmente causa a maioria dos incidentes são erros de configuração do próprio cliente, como permissões mal definidas, credenciais expostas ou ausência de monitoramento.

Portanto, migrar para a cloud não elimina as responsabilidades, apenas muda o foco. Segurança deixa de ser apenas uma barreira no perímetro da rede e passa a ser um processo contínuo de gestão de riscos, conformidade regulatória e boas práticas de configuração. Em resumo, o provedor é responsável por proteger a infraestrutura global que executa todos os serviços oferecidos, enquanto o cliente é responsável por proteger seus dados e aplicações que rodam nessa infraestrutura.

Isso fica ainda mais evidente ao analisar a imagem a seguir. Ela mostra de forma evidente qual são as responsabilidades do Cliente e quais são as do Provedor.

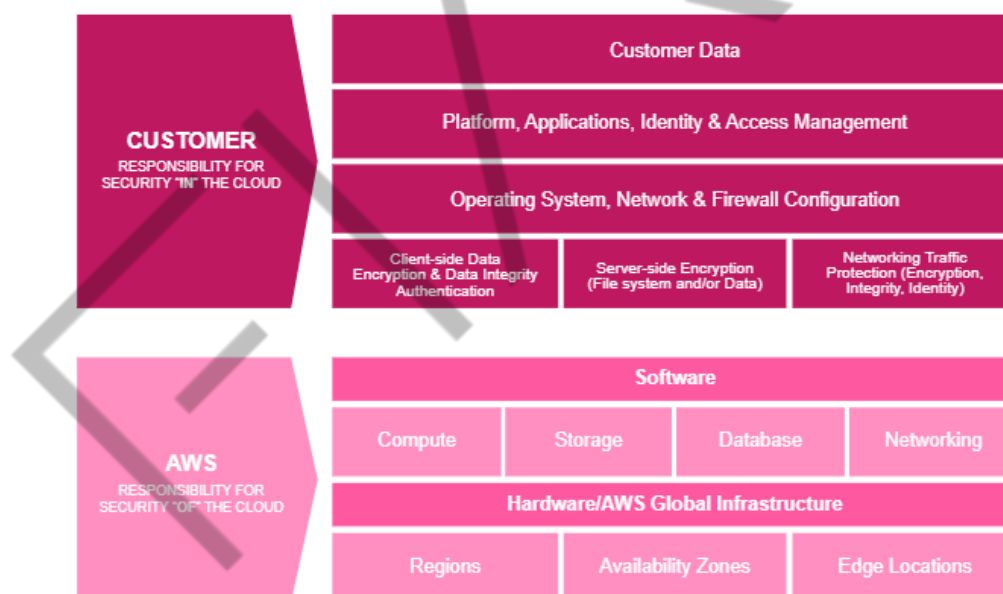


Figura 3 – Modelo de Responsabilidade Compartilhada
Fonte: AWS (2024)

Migrar de um datacenter local para a cloud também não significa “abandonar tudo e colocar 100% lá dentro”. Muitas empresas adotam o modelo híbrido, que combina infraestrutura local com serviços em cloud.

Essa mudança fica ainda mais evidente quando olhamos para os diferentes modelos de serviço: IaaS, PaaS e SaaS. Vamos falar mais sobre cada um deles nas

próximas aulas. Eles representam uma transição clara da propriedade total do datacenter físico para um modelo de serviço como commodity, no qual parte ou quase toda a responsabilidade pela infraestrutura é transferida ao provedor.

Agora que ficou claro que a segurança na arquitetura em cloud segue um modelo de responsabilidade compartilhada, fica evidente que as maiores vulnerabilidades não estão no provedor de cloud em si, mas sim na forma como os clientes utilizam e configuram esses serviços. Esse é um ponto muito importante, porque muitas empresas migram rapidamente para a cloud em busca de agilidade e redução de custos, mas não adaptam sua estratégia de segurança ao novo ambiente.

Com isso, o temos observado cada vez mais incidentes de grande impacto associados a erros básicos, como bancos de dados expostos sem senha, buckets de armazenamento configurados como públicos ou credenciais de administradores publicadas acidentalmente em repositórios de código. Esses problemas não são falhas da tecnologia, mas sim reflexo da falta de processos de segurança adequados.

Para organizar e compreender melhor sobre esses riscos, a comunidade de segurança desenvolveu referências globais. Entre elas, destaca-se o trabalho da OWASP (Open Web Application Security Project), uma organização internacional sem fins lucrativos conhecida por criar guias de boas práticas de segurança para aplicações e, mais recentemente, também para ambientes em cloud.

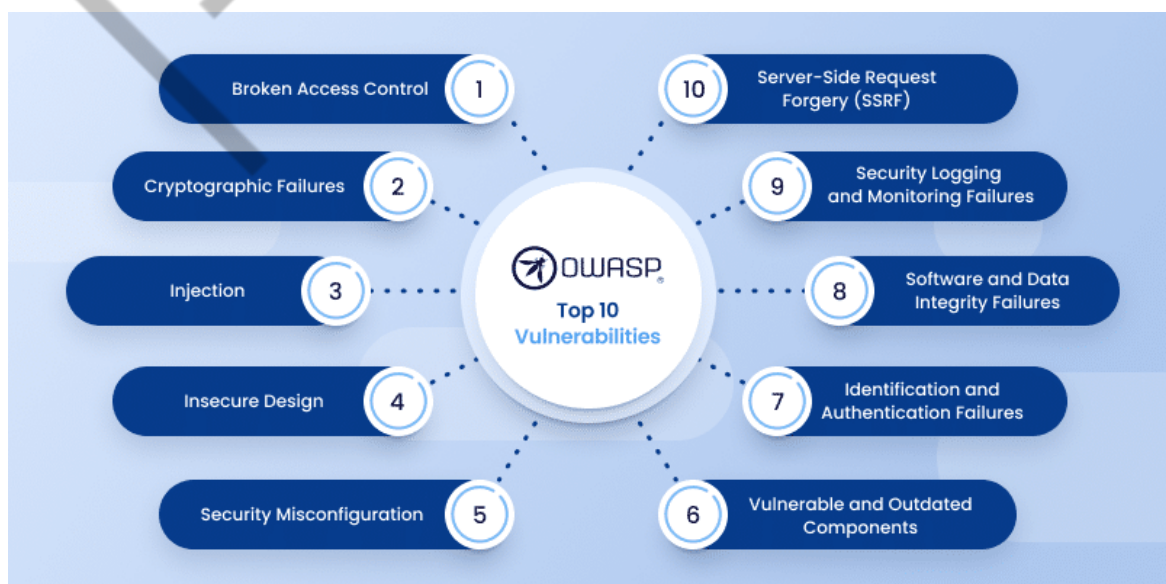


Figura 4 – OWASP TOP 10
Fonte: OWASP (2024)

O OWASP Top 10 é um documento de conscientização padrão para pessoas desenvolvedoras e profissionais de segurança de aplicações. Ele descreve os riscos de segurança mais críticos em aplicações e como preveni-los.

A01:2021 – Controle de Acesso Quebrado (Broken Access Control)

O controle de acesso deve garantir que usuários não autorizados sejam impedidos de acessar informações ou executar ações fora de sua permissão. Quando essa política não é implementada corretamente, podem ocorrer divulgação indevida de informações, modificação ou destruição de dados e ações fora do limite autorizado. Isso quebra diretamente o modelo de segurança conhecido como tríade Confidencialidade, Integridade e Disponibilidade (CIA).

Exemplos (CWE): CWE-200 (exposição de informações sensíveis a ator não autorizado), CWE-201 (inserção de informação sensível em dados transmitidos), CWE-352 (Cross-Site Request Forgery).

Como precaução, você deve negar acesso por padrão e implementar mecanismos de controle reutilizáveis. Além disso, é importante registrar a propriedade de recursos ao invés de permissões manuais, aplicar a lógica de negócio diretamente nos modelos de domínio, desabilitar listagem de diretórios no servidor web, registrar falhas de acesso e gerar alertas em caso de repetição, aplicar rate limiting em APIs e invalidar sessões e tokens corretamente.

Atualmente, essa vulnerabilidade continua amplamente explorada. O crescimento de APIs públicas e microsserviços aumentou a superfície de ataque. Hoje, a recomendação é reforçar controle de acesso baseado em contexto (como hora, localização, dispositivo) e aplicar Zero Trust para minimizar brechas.

A02:2021 – Falhas Criptográficas (Cryptographic Failures)

Refere-se a falhas na proteção de dados sensíveis, tanto em repouso quanto em trânsito. Isso inclui o uso de algoritmos fracos, chaves mal gerenciadas, armazenamento em texto puro e reutilização de vetores de inicialização.

Exemplos (CWE): CWE-259 (uso de senha hard-coded), CWE-327 (uso de algoritmo criptográfico fraco), CWE-331 (entropia insuficiente).

Para se prevenir é necessário classificar dados, evitar armazenamento desnecessário, criptografar dados com algoritmos modernos e usar TLS com parâmetros seguros. É possível ainda aplicar HSTS, evitar protocolos legados (FTP, SMTP), usar funções adaptativas para armazenamento de senhas (bcrypt, scrypt, PBKDF2), evitar funções de hash obsoletas como MD5 e SHA-1 e implementar gestão adequada de chaves.

Hoje, os ataques baseados em criptografia quebrada continuam crescendo devido a senhas fracas e más práticas em armazenamento de chaves em cloud. Regulamentações como GDPR e LGPD tornaram esse tópico ainda mais sensível, especialmente com a popularização de ransomware e vazamentos massivos de dados.

A03:2021 – Injeção (Injection)

Ocorre quando dados fornecidos por usuários são interpretados como comandos, em vez de simples informações. Isso pode levar a SQL Injection, NoSQL Injection, execução de comandos no sistema operacional e outros.

Exemplos (CWE): CWE-79 (Cross-Site Scripting), CWE-89 (SQL Injection), CWE-73 (Controle Externo de Nome de Arquivo ou Caminho).

Prevenção: usar APIs seguras e parametrizadas, validar dados do lado do servidor, limitar consultas SQL e aplicar whitelists. Além disso, é possível utilizar ferramentas de segurança como SAST, DAST e IAST no pipeline de CI/CD. Muitas ferramentas de WAF ajudam a proteger sua aplicação por meio de regras de segurança.

Atualmente, as injeções ainda são muito exploradas, principalmente em bancos NoSQL e APIs modernas. Ferramentas automatizadas de ataque estão cada vez mais eficazes. O XSS e o SQL Injection seguem relevantes, mas a tendência atual é a exploração de GraphQL Injection.

A04:2021 – Design Inseguro (Insecure Design)

Esse item relaciona-se a falhas de arquitetura, ou ausência de controles validados no projeto. Mesmo implementações “perfeitas” não conseguem corrigir falhas de design inseguro.

Exemplos (CWE): CWE-209 (exposição de informações em mensagens de erro), CWE-256 (armazenamento não protegido de credenciais), CWE-501 (violação de fronteira de confiança), CWE-522 (credenciais insuficientemente protegidas).

Pensando em como prevenção, você pode aplicar ciclo de vida seguro de desenvolvimento (SDLC), usar padrões de design seguros, fazer modelagem de ameaças, incluir especialistas em AppSec no design, separar camadas de sistema e rede e restringir recursos por usuário.

Sobre o guia do SDLC, recomendo você ler o livro abaixo, explica com muitos detalhes as melhoras práticas.

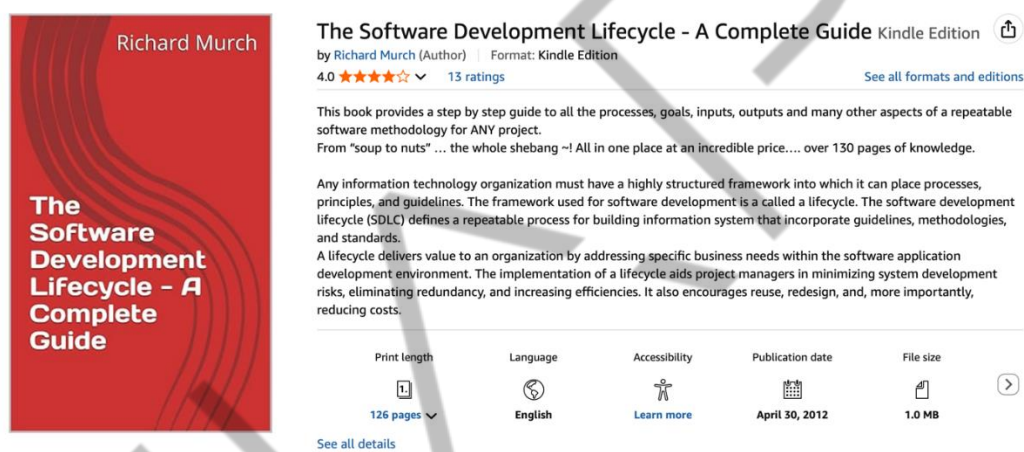


Figura 5 – Livro – The Software Lifecycle – A Comple Guide
Fonte: Kindle Edition- AWS (2012)

A05:2021 – Má Configuração de Segurança (Security Misconfiguration)

Esse item é muito importante. Este problema ocorre com frequência nas empresas, principalmente devido ao uso de configurações padrão, já que falhas de configuração ainda são muito comuns. Estas falhas incluem habilitação de serviços desnecessários, uso de contas padrão, ausência de hardening, desativação de recursos de segurança e uso de softwares desatualizados.

Exemplos (CWE): CWE-16 (Configuração), CWE-611 (restrição imprópria de entidades externas em XML).

Pensando em prevenção, você deve automatizar processos de configuração segura, aplicar hardening e remover serviços não utilizados. Além disso, é necessário revisar permissões em cloud, enviar cabeçalhos de segurança e verificar configurações periodicamente.

Com o aumento da adoção de containers e Kubernetes, más configurações em ambientes orquestrados estão entre os principais vetores de ataque. O OWASP chama atenção para cloud misconfiguration como uma das maiores causas de vazamentos recentes.

A06:2021 – Componentes Vulneráveis e Desatualizados (Vulnerable and Outdated Components)

Quando bibliotecas, frameworks e softwares não são atualizados, eles se tornam alvos de exploração. Esse é um risco crítico devido ao uso massivo de código de terceiros.

Exemplos (CWE): CWE-1104 (uso de componentes de terceiros não mantidos).

Como prevenção, é preciso remover as dependências não utilizadas, monitorar versões de bibliotecas e frameworks, usar ferramentas de análise de composição de software (SCA), obter componentes apenas de fontes confiáveis, aplicar patches rapidamente e monitorar CVEs e NVD.

Essa categoria ganhou ainda mais destaque porque ataques à cadeia de suprimentos (supply chain attacks) estão aumentando, como no caso de bibliotecas npm ou PyPI comprometidas. Hoje, medidas reforçadas incluem a automatização do patch management e o uso de repositórios internos confiáveis.

A07:2021 – Falhas de Identificação e Autenticação (Identification and Authentication Failures)

Essas falhas ocorrem quando sistemas permitem credenciais fracas, reutilização de senhas, sessões mal gerenciadas ou ausência de configuração de autenticação multifator.

Exemplos (CWE): CWE-297 (validação incorreta de certificado), CWE-287 (autenticação imprópria), CWE-384 (fixação de sessão).

Pensando em prevenção, podemos implementar MFA, bloquear credenciais padrão, verificar força de senhas e endurecer processos de registro. É possível ainda a recuperação de conta, limitar tentativas de login, adotar gerenciadores de sessão seguros e invalidar sessões após logout.

Atualmente, os ataques de credential stuffing e phishing avançado continuam crescendo. Hoje, a recomendação é ampliar o uso de autenticação sem senha (passwordless) e adoção massiva de FIDO2/WebAuthn.

A08:2021 – Falhas de Integridade de Software e Dados (Software and Data Integrity Failures)

Essa categoria se relaciona à falta de proteção contra adulteração de código ou dados, incluindo pipelines CI/CD inseguros e atualizações automáticas sem validação.

Exemplos (CWE): CWE-829 (inclusão de funcionalidade de fonte não confiável), CWE-494 (download de código sem verificação de integridade), CWE-502 (desserialização insegura).

Como prevenção, é possível verificar assinaturas digitais, usar repositórios confiáveis e proteger pipelines CI/CD com segregação. Além disso, podemos adotar controle de acesso, revisar códigos e configurações e validar dados transmitidos.

A09:2021 – Falhas de Logging e Monitoramento (Security Logging and Monitoring Failures)

A falta de registros e monitoramento dificulta a detecção de incidentes. Estudos indicam que o tempo médio para detectar um ataque ainda é de meses, o que aumenta significativamente o impacto.

Exemplos (CWE): CWE-778 (log insuficiente), CWE-117 (neutralização imprópria de saída para logs), CWE-223 (omissão de informações de segurança).

Uma boa forma de prevenção é registrar logins e falhas, armazenar logs em formatos adequados, proteger os logs contra adulteração, auditar grandes transações, implementar monitoramento efetivo e manter um plano de resposta a incidentes.

Com o crescimento de ataques avançados (como ransomware), a recomendação é integrar SIEM + SOAR e aplicar detecção baseada em comportamento para resposta mais rápida.

A10:2021 – Falsificação de Requisição no Servidor (SSRF – Server-Side Request Forgery)

Permite que invasores manipulem aplicações para enviar requisições para destinos arbitrários, inclusive em redes internas protegidas por firewall.

Dicas para prevenção é segmentar redes, aplicar firewalls com negação por padrão, validar e sanitizar URLs de entrada, usar listas de permissões (allow lists), utilizar WAF, desabilitar redirecionamentos automáticos e evitar expor respostas brutas ao cliente.

Analizando esse item, o SSRF cresceu em criticidade devido ao uso de cloud e APIs. Hoje, recomenda-se usar segurança em camadas (rede, aplicação e API Gateway) e monitorar tentativas de exploração de serviços internos expostos.

O OWASP Top 10 segue sendo a principal referência mundial para conscientização sobre segurança de aplicações. As dez categorias apresentadas não devem ser vistas apenas como uma lista de problemas técnicos, mas sim como um guia estratégico para que as empresas adotem práticas seguras desde o projeto até a produção. A prevenção passa por três pilares principais: design seguro, implementação correta e operações contínuas de monitoramento e resposta.

É importante destacar que a segurança não é estática. Mesmo com controles bem aplicados, novas ameaças surgem diariamente. Por isso, é essencial que as empresas adotem práticas como DevSecOps, gestão de vulnerabilidades contínua, auditorias regulares, modelagem de ameaças e educação constante de desenvolvedores e equipes de TI.

Ao aplicar as medidas sugeridas e manter-se atualizado com os relatórios do OWASP, as organizações não apenas reduzem os riscos de ataques e vazamentos, mas também aumentam a confiança dos clientes e parceiros, fortalecem sua reputação e garantem conformidade com regulamentações de privacidade e proteção de dados.

No fim, a segurança será sempre um jogo de resistência e adaptação: atacantes continuarão tentando explorar falhas, mas aqueles que se antecipam, monitoram e evoluem seus controles terão muito mais chances de proteger suas aplicações e informações críticas.

As consequências de um incidente de segurança na cloud podem ser devastadoras, indo muito além da perda de dados. Os impactos se desdobram em perdas financeiras diretas, danos à reputação da marca (que podem levar anos para serem reparados) e severas consequências legais e regulatórias.

Ao longo deste material, você entendeu que a computação em cloud trouxe enormes benefícios para empresas e profissionais, como escalabilidade, flexibilidade e redução de custos. No entanto, esses ganhos também vieram acompanhados de novos riscos e ameaças que exigem atenção constante.

Ao analisar tudo o que foi abordado, observa-se que as ameaças mais comuns — como configurações incorretas, exposição de credenciais, ataques internos e exploração de APIs — demonstram que a segurança em cloud não é apenas um desafio técnico, mas também organizacional.

É fundamental compreender o modelo de responsabilidade compartilhada, no qual provedores e clientes têm papéis distintos, porém igualmente importantes na proteção dos dados e serviços. Por isso, reforça-se a importância de cada um entender sua responsabilidade.

Adote práticas sólidas de segurança, como gestão de identidades e acessos, criptografia, monitoramento contínuo e resposta a incidentes. Isto não deve ser visto como um custo adicional, mas sim como um investimento estratégico para proteger a reputação e a continuidade do negócio.

Mais do que tecnologia, segurança em nuvem envolve processos bem definidos e uma cultura organizacional de prevenção. Somente assim será possível aproveitar todo o potencial da cloud computing de forma confiável e resiliente.

MERCADO, CASES E TENDÊNCIAS

Insights do *Cloud and Threat Report 2025* (Netskope)

O mais recente relatório da [Netskope](#) revela que **mais de 35% de todo o tráfego corporativo em nuvem envolve aplicativos não gerenciados**, muitos dos quais são usados sem aprovação da TI (Shadow IT). Essa tendência amplia a superfície de ataque e expõe as organizações a vazamento de dados, ataques baseados em SaaS e uso indevido de IA generativa.

O QUE VOCÊ VIU NESTA AULA?

Nesta aula, exploramos o cenário dinâmico e desafiador da segurança em ambientes em cloud. Falamos sobre o crescimento do uso da cloud computing e as diferenças fundamentais em relação aos datacenters tradicionais.

Exploramos sobre o Modelo de Responsabilidade Compartilhada e, em seguida, mergulhamos fundo nas 10 principais ameaças de segurança para aplicações nativas da nuvem, de acordo com a OWASP. Para cada ameaça, analisamos sua definição, exemplos do mundo real, e as boas práticas essenciais para mitigação.

Lembre-se que a segurança na nuvem não é um destino, mas uma jornada contínua de aprendizado, adaptação e melhoria. Revisite este material e os vídeos sempre que precisar reforçar seus conhecimentos!

REFERÊNCIAS

APPSEC ENGINEER. **AWS Shared Responsibility Model: Capital One Breach Case Study**. 2023. Disponível em: <https://www.appsecengineer.com/blog/aws-shared-responsibility-model-capital-one-breach-case-study>. Acesso em: 13 out. 2025.

CERTERA. **Mitigating the OWASP Top 10 Vulnerabilities**. 2024. Disponível em: <https://certera.com/blog/mitigating-the-owasp-top-10-vulnerabilities/>. Acesso em: 13 out. 2025.

DOTSON, C. **Practical Cloud Security**. 2. ed. Sebastopol: O'Reilly Media, 2019.

GARTNER. **Gartner Forecasts Worldwide Public Cloud End-User Spending to Surpass \$675 Billion in 2024**. 2024. Disponível em: <https://www.gartner.com/en/newsroom/press-releases/2024-05-20-gartner-forecasts-worldwide-public-cloud-end-user-spending-to-surpass-675-billion-in-2024>. Acesso em: 13 out. 2025.

OWASP. **Cloud-Native Application Security Top 10**. 2025. Disponível em: <https://owasp.org/www-project-cloud-native-application-security-top-10/>. Acesso em: 13 out. 2025.

OWASP. **OWASP Top Ten**. 2021. Disponível em: <https://owasp.org/www-project-top-ten/>. Acesso em: 13 out. 2025.

THALES GROUP. **2025 Thales Data Threat Report**. 2024. Disponível em: <https://cpl.thalesgroup.com/data-threat-report>. Acesso em: 13 out. 2025.

WALLACE, G. **Software Development Lifecycle – Complete Guide**. [S. l.]: Amazon, 2012.

PALAVRAS-CHAVE

Cloud Security. OWASP. Segurança em Cloud.

OWASP



POS TECH